

Curso de Especialización Ciberseguridad en las TIC

Práctica 1. Hardening Ubuntu Server - Securización ssh.

Objetivos

- Acceder remotamente con certificado.
- Fortalecer con medidas de seguridad el servicio ssh.
- Auditar con Inav.
- Auditar con Lynis.
- Identificar medidas extras de fortificación ssh.

Resumen

Autora: Marina del Pilar López Oliva

Febrero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	23/02/2026	Adaptación de la plantilla
1.1	25/02/2026	Documentación de la práctica.

Índice de Contenidos

1. Introducción.....	4
2. Apartado 1.....	4
3. Apartado 2.....	11
4. Apartado 3.....	18
5. Apartado 4.....	21
6. Apartado 5.....	23
7. Apartado 6.....	24
8. Conclusiones.....	30
9. Webgrafía.....	30

1. Introducción

En esta práctica vamos a detallar el proceso de bastionado del servicio SSH en un servidor Ubuntu con apache. El objetivo principal es elevar los niveles de seguridad mediante la eliminación de autenticación por contraseña, la restricción de privilegios y el cumplimiento de estándares internacionales. Vamos a documentar las configuraciones aplicadas siguiendo los contenidos Ut6, propuesto por el profesor, y se validan mediante herramientas de auditoría. También se aplicarán nuevas medidas siguiendo las guías y buenas prácticas oficiales para el hardening del ssh.

2. Apartado 1.

En primer lugar, hemos generado un par de claves RSA de 4096 bits en un cliente Ubuntu utilizando ssh-keygen. Hemos asignado el nombre de “clienteLinux” y hemos establecido un código secreto (passphrase) para proteger la clave privada. Hemos seguido los pasos correspondientes del punto 2.3 de los contenidos.

```
ubuntu@ubuntu2204:~$ eval "$(ssh-agent -s)"
Agent pid 4245
ubuntu@ubuntu2204:~$ ssh-keygen -t rsa -b 4096
Generating public/private rsa key pair.
Enter file in which to save the key (/home/ubuntu/.ssh/id_rsa): clienteLinux
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in clienteLinux
Your public key has been saved in clienteLinux.pub
The key fingerprint is:
SHA256:hCpv9FcnuZXRJhdfGEbny6cxEhbzdubBvc7snL9hjs ubuntu@ubuntu2204
The key's randomart image is:
+---[RSA 4096]---+
|           + +..*  |
|          .o + *..* |
|         . .. o +..+|
|        . . . o.oo. |
|       . o  S.o .+o.+|
|      + .   o.o  .+. |
|     o . o.   o.. |
|    . .o.   . oE+. |
|   oo.    o.+++ |
+-----[SHA256]-----+
```

Figura 1. Generación del par de claves clienteLinux con ssh-keygen.

A continuación, hemos copiado las claves al directorio correspondiente (.ssh) y hemos verificado que esté en la ubicación correcta.

```
ubuntu@ubuntu2204:~$ cp clienteLinux.pub clienteLinux .ssh/
ubuntu@ubuntu2204:~$ ls .ssh/
authorized_keys  clienteLinux.pub  id_rsa.pub  known_hosts.old
clienteLinux     id_rsa            known_hosts
ubuntu@ubuntu2204:~$ cat .ssh/clienteLinux.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCV3vn6DSN7XWDhh/F+qhp0AsWwVAYcP6RQT/Qxfb88
bin/m4tU+Uh4+Pmb4bJJWbnpWkaGdI+dV7SyET0a5ov/yNKnoL0Jxheek7SpYCzAx5EyuZKKQQ+F+VH
9ClSqIa3IuVX9y7ASGBjRhEJ6wN/BqC73aeI4gtxlwGe1GkQb/mEB8H3iPLkXzY3/6PSSfYtYd1dUXn6
9HTsblVvwCJw0TmeTNCUQ0yXYka3iUXu8i3Gavhf8sKazQksGDp62b5FJfCzrcHcSVgNxRBdHQGJX3U0
QhBfY6uTwapTG5DY/mnI98SY/KR/3BWPoA9z2JUlbKH00LE7gy+0LXyLBzLAGS3HSpdneJFydAiSkV02
7a31GC3MrsX4Grfd300o0g2PRl0Ehjmqmc6NhYUWVaxZ2UZEZ6v9x1+v+dEcQM8z93lb1Qc0pHH8D/Dm
t0+HfbQdhLf+8g/69vttklJ+p685W0YLFZ+pkTQubPcscvVfoAeWhsLjLAXSdEWuRypb3YtYsrQ0sgqv
/fJOfS5+6RP4X8Wk9c8y3Zz7jE4XCYjJkRFnc6WZREGpA8rh9ZUD50NtWwRV1HH4NsgpkFFT0g0i1xgf
tQgw6IUvftDPUEdVspfkjwvRHIdrcRkNgIwFKQsLb2VOA2X3QwILPiwbRmd2agrc7v2cf69+1rwMm8sc
lw== ubuntu@ubuntu2204
```

Figura 2. Copia de las claves a .ssh y visualización de la clave pública.

Para transferir la clave pública al servidor de forma segura, hemos utilizado el comando `ssh-copy-id`, que automáticamente añade la clave al archivo `authorized_keys` del usuario `admin`.

```
ubuntu@ubuntu2204:~$ ssh-copy-id -p 22445 -i .ssh/clienteLinux.pub admin@192.168.100.166
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: ".ssh/clienteLinux.pub"
The authenticity of host '[192.168.100.166]:22445 ([192.168.100.166]:22445)' can't be established.
ED25519 key fingerprint is SHA256:CItNjNtaNhJiiE9suFmhWYtCEAmD5kJPbzx3h7yv6s.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? YES
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are alre
ady installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to insta
ll the new keys
admin@192.168.100.166's password:

Number of key(s) added: 1

Now try logging into the machine, with:  "ssh -p 22445 'admin@192.168.100.166'"
and check to make sure that only the key(s) you wanted were added.
```

Figura 3. Copia de la clave pública al servidor.

Finalmente, hemos comprobado la conexión utilizando la clave privada almacenada en el cliente. El sistema solicitó la passphrase que establecimos al crearla, y no la contraseña del usuario `admin`, demostrando el correcto funcionamiento de la autenticación por certificado.

```
ubuntu@ubuntu2204:~$ ssh -p 22445 -i .ssh/clienteLinux admin@192.168.100.166
Enter passphrase for key '.ssh/clienteLinux':
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of mar 24 feb 2026 16:42:13 UTC

System load:  0.0               Processes:            106
Usage of /:   13.0% of 24.44GB   Users logged in:     1
Memory usage: 19%              IPv4 address for enp0s3: 192.168.100.166
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 23 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

*** Es necesario reiniciar el sistema ***
Last login: Tue Feb 24 16:23:29 2026 from 192.168.100.11
```

Figura 4. Acceso al servidor mediante clave privada desde un cliente Ubuntu.

En Windows 11, otro cliente conectado a la misma red, lo primero que hemos hecho es verificar la instalación del cliente OpenSSH mediante PowerShell.

```
PS C:\WINDOWS\system32> Get-WindowsCapability -Online | ? Name -like 'OpenSSH*'

Name : OpenSSH.Client~~~~0.0.1.0
State : Installed

Name : OpenSSH.Server~~~~0.0.1.0
State : NotPresent
```

Figura 5. Comprobación de la instalación del cliente OpenSSH en PowerShell.

Como está instalado, no hace falta instalarlo, pues ya debería funcionar correctamente.

Entonces, generamos un par de claves, como vemos a continuación siguiendo también los pasos del punto 2.3 de los contenidos. En este caso, lo nombraremos “clienteWindows”. Y lo pasaremos, como en linux, a su repositorio adecuado, .ssh.

```
PS C:\Users\marina> ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (C:\Users\marina\.ssh/id_ed25519): clienteWindows
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in clienteWindows
Your public key has been saved in clienteWindows.pub
The key fingerprint is:
SHA256:Xo2luVMivxmTTP8CWp4uVqBbULxSplFx6a4dUvQk5ng marina@W11-iescamp
The key's randomart image is:
+--[ED25519 256]--+
|      oo...      |
|      . = .      |
|      * B +      |
|    + + E . *    |
|    + =S * o     |
|      . o.*+ =   |
|      o O.+O    |
|      . = +o.B . |
|      . o. +.o   |
+----[SHA256]-----+
PS C:\Users\marina> cp .\clienteWindows .\.ssh\clienteWindows
PS C:\Users\marina> cp .\clienteWindows.pub .\.ssh\clienteWindows.pub
PS C:\Users\marina> ls .\.ssh\

Directorio: C:\Users\marina\.ssh

Mode                LastWriteTime         Length Name
----                -
-a-----          24/02/2026   18:51             464 clienteWindows
-a-----          24/02/2026   18:51             101 clienteWindows.pub
-a-----          24/02/2026   18:48             870 known_hosts
-a-----          24/02/2026   18:48             106 known_hosts.old
```

Figura 6. Generación del par de claves clienteWindows en PowerShell.

A continuación, hemos configurado el servicio ssh-agent para que se inicie manualmente, y hemos añadido la clave privada al agente, lo que permite no tener que especificar la ruta de la clave en cada conexión.

```
PS C:\Users\marina> Get-Service -Name ssh-agent | Set-Service -StartupType Manual
PS C:\Users\marina> Start-Service ssh-agent
```

Figura 7. Configuración del servicio ssh-agent.

```
PS C:\Users\marina> Get-Service -Name ssh-agent | Set-Service -StartupType Manual
PS C:\Users\marina> Start-Service ssh-agent
PS C:\Users\marina> ssh-add .\.ssh\clienteWindows
Enter passphrase for .\.ssh\clienteWindows:
Identity added: .\.ssh\clienteWindows (marina@W11-iescamp)
```

Figura 8. Adición de la clave privada al agente SSH.

Por último, hemos copiado la clave pública al servidor, añadiéndola al archivo authorized_keys del usuario admin.

```
PS C:\Users\marina> scp -P 22445 .\ssh\clienteWindows.pub admin@192.168.100.166:~/.ssh/authorized_keys
admin@192.168.100.166's password:
clienteWindows.pub                                100% 101   3.8KB/s   00:00
```

Figura 9. Copia de la clave pública de clienteWindows al servidor.

Con la clave pública en el servidor y la privada cargada en el ssh-agent, hemos realizado la conexión sin necesidad de especificar la clave ni la contraseña.

```
PS C:\Users\marina> ssh -p 22445 admin@192.168.100.166
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of mar 24 feb 2026 17:56:52 UTC

System load:  0.08               Processes:           108
Usage of /:   13.0% of 24.44GB   Users logged in:    1
Memory usage: 19%               IPv4 address for enp0s3: 192.168.100.166
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 23 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

*** Es necesario reiniciar el sistema ***
Last login: Tue Feb 24 17:48:45 2026 from 192.168.100.172
admin@iescamp-webserver:~$
```

Figura 10. Acceso al servidor desde Windows mediante autenticación por clave.

Por último para este apartado, hemos utilizado PuttyGen. Se puede utilizar de dos maneras, utilizándose para generar un par de claves con passphrase en formato de PuTTY.

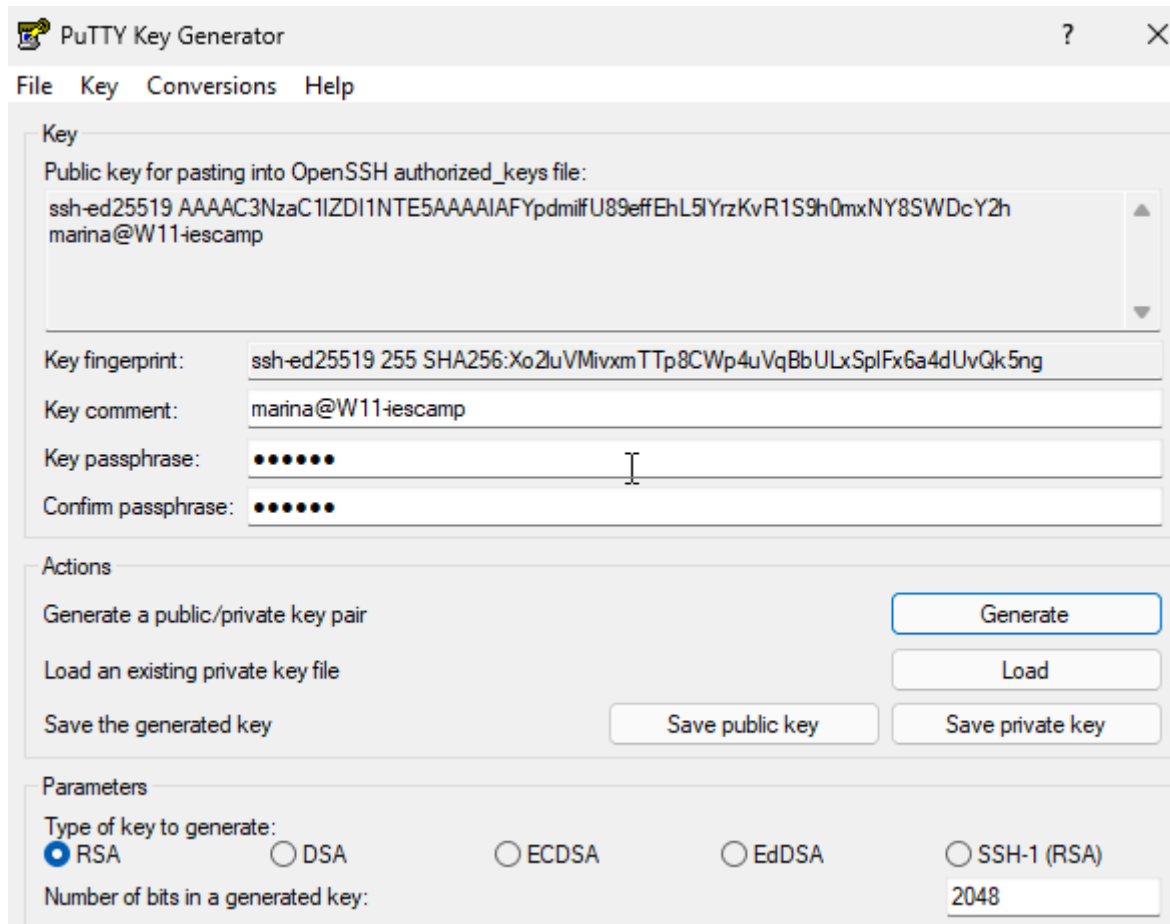


Figura 11. Generación de par de claves en PuTTYgen.

O para importar las claves generadas anteriormente y exportarlas en el formato de PuTTY. En mi caso, he importado "clienteWindows" y la he exportado "ClienteWindows1" con el formato de PuTTY.

Hemos configurado una nueva sesión PuTTY con la dirección IP del servidor y el puerto correspondiente, 22445. En la sesión de autenticación, hemos especificado el archivo de clave privada generado.

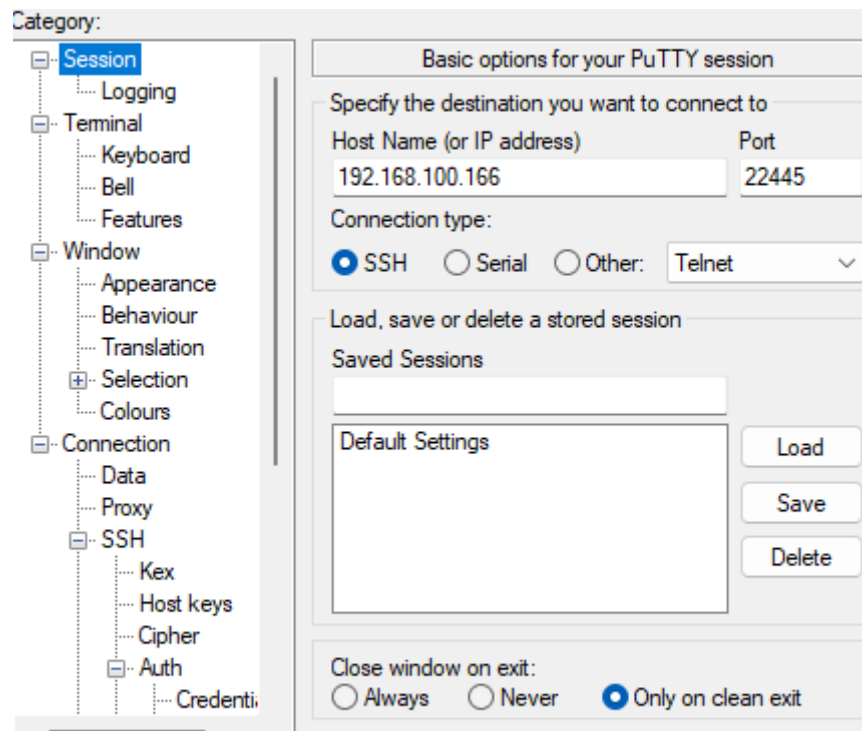


Figura 12. Configuración básica de la sesión SSH en PuTTY.

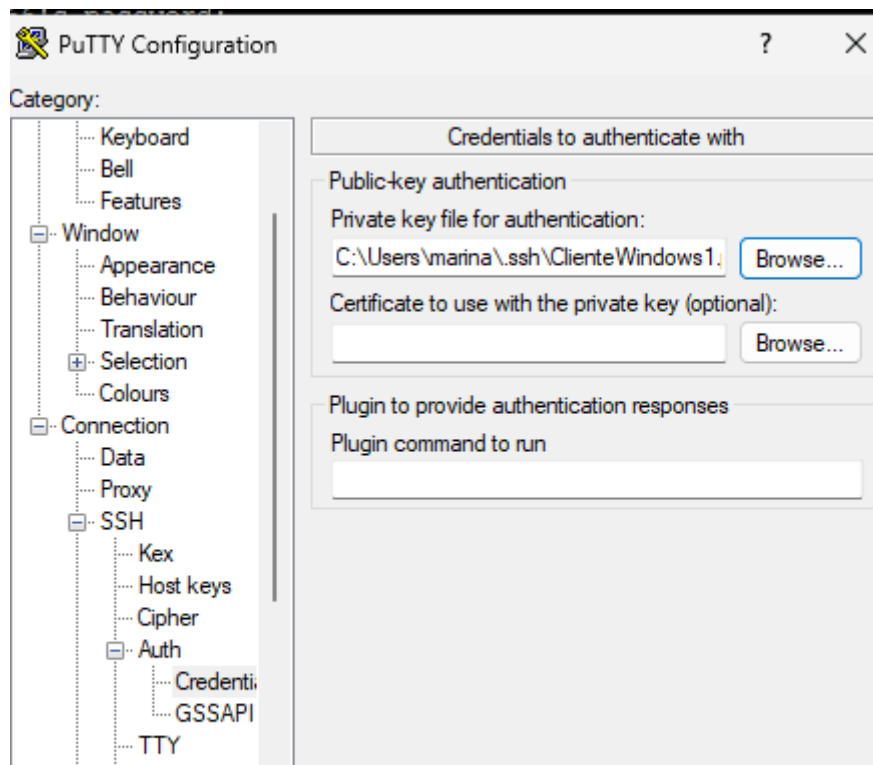
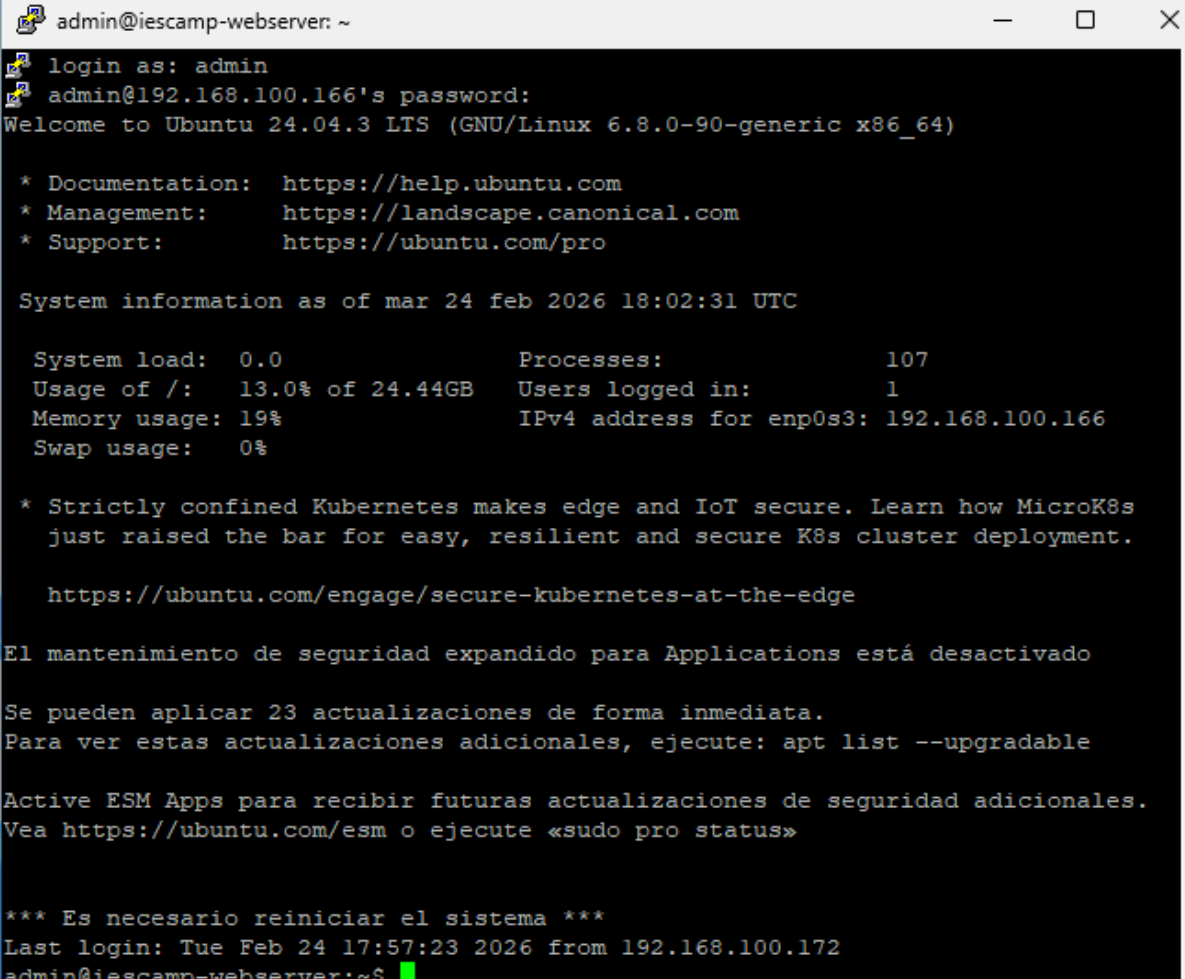


Figura 13. Especificación del archivo de clave privada en la configuración de autenticación.

La clave pública generada se añadió manualmente al archivo `authorized_keys` del servidor, completando así la configuración para el acceso mediante PuTTY.



```
admin@iescamp-webserver: ~  
login as: admin  
admin@192.168.100.166's password:  
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:       https://ubuntu.com/pro  
  
System information as of mar 24 feb 2026 18:02:31 UTC  
  
System load:  0.0          Processes:           107  
Usage of /:   13.0% of 24.44GB Users logged in:       1  
Memory usage: 19%         IPv4 address for enp0s3: 192.168.100.166  
Swap usage:   0%  
  
* Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s  
  just raised the bar for easy, resilient and secure K8s cluster deployment.  
  
  https://ubuntu.com/engage/secure-kubernetes-at-the-edge  
  
El mantenimiento de seguridad expandido para Applications está desactivado  
  
Se pueden aplicar 23 actualizaciones de forma inmediata.  
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable  
  
Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.  
Vea https://ubuntu.com/esm o ejecute «sudo pro status»  
  
*** Es necesario reiniciar el sistema ***  
Last login: Tue Feb 24 17:57:23 2026 from 192.168.100.172  
admin@iescamp-webserver:~$
```

Figura 14. Acceso al servidor mediante PuTTY.

3. Apartado 2.

En este apartado hemos implementado las medidas de seguridad requeridas en el Ubuntu con apache. Para ello, hemos editado el archivo de configuración `/etc/ssh/sshd_config` y hemos añadido o modificado las directivas necesarias. También hemos realizado pruebas para verificar que las medidas funcionen correctamente. Después de cada modificación al archivo, hemos reiniciado el servicio ssh del servidor.

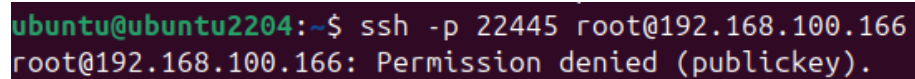
Primero se nos pide que no sea posible el acceso remoto con el usuario root. Para ello, hemos añadido la directiva `"PermitRootLogin no"` en el archivo de configuración, que deshabilita el acceso directo del usuario root por SSH.



```
admin@iescamp-webserver: ~  
Session Acciones Editar Vista Ayuda  
GNU nano 7.2 /etc/ssh/sshd_config  
PermitRootLogin no
```

Figura 15. Modificación del sshd_config para impedir el acceso remoto con root.

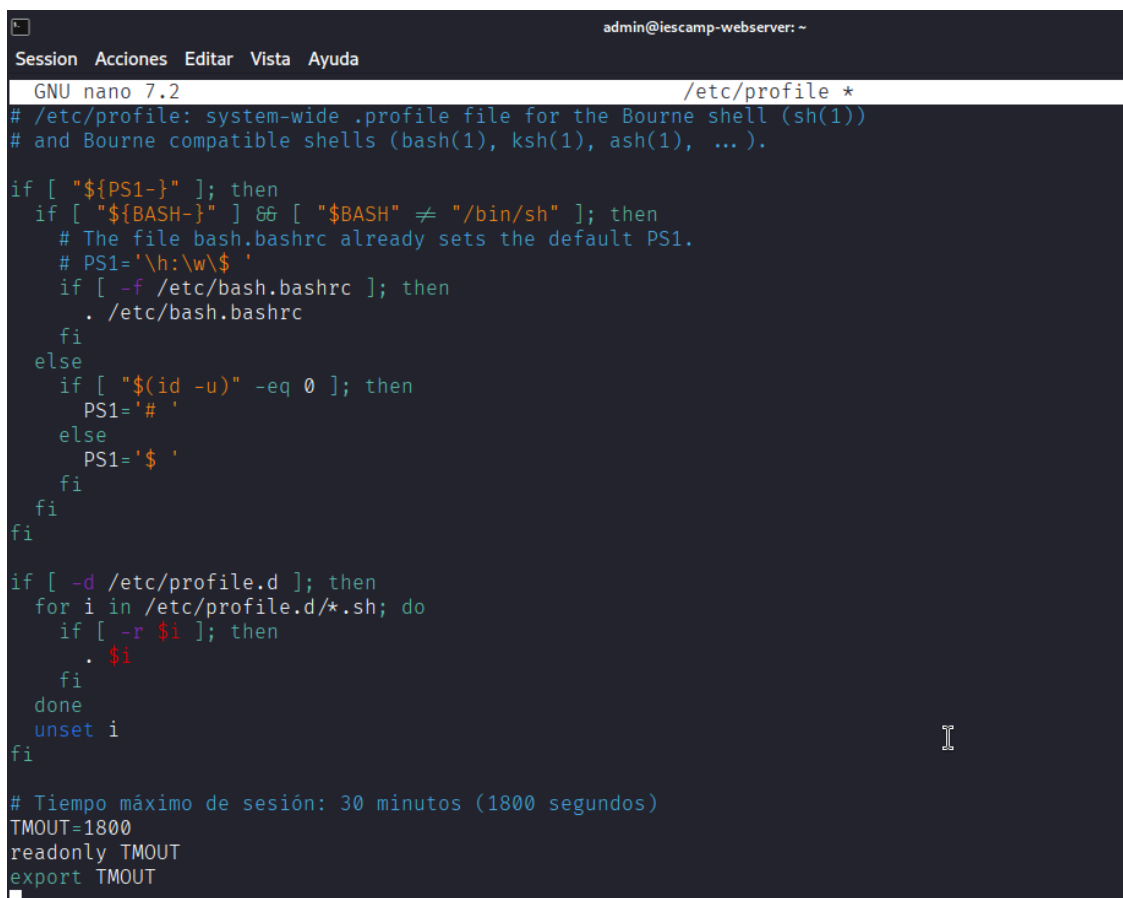
Hemos intentado conectarnos como root desde un cliente con acceso, y hemos podido comprobar que funciona la directiva ya que el acceso ha sido denegado.



```
ubuntu@ubuntu2204:~$ ssh -p 22445 root@192.168.100.166  
root@192.168.100.166: Permission denied (publickey).
```

Figura 16. Intento de acceso como root denegado.

Después, nos pide que tendría que existir un tiempo máximo de sesión de 30 minutos. Para ello, hemos configurado la variable de entorno TMOUT en el archivo /etc/profile. Esta variable afecta a todos los usuarios del sistema. Lo hemos configurado aquí, porque configurarlo desde el archivo /etc/ssh/sshd_config podría tener problemas con el siguiente punto.

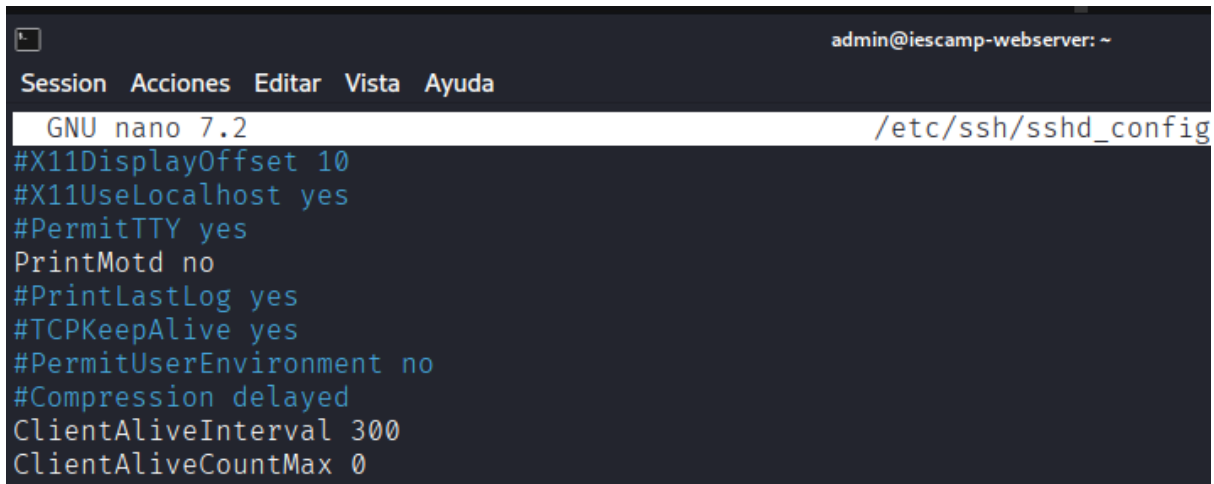


```
admin@iescamp-webserver: ~  
Session Acciones Editar Vista Ayuda  
GNU nano 7.2 /etc/profile *  
# /etc/profile: system-wide .profile file for the Bourne shell (sh(1))  
# and Bourne compatible shells (bash(1), ksh(1), ash(1), ...).  
  
if [ "${PS1-}" ]; then  
  if [ "${BASH-}" ] && [ "$BASH" ≠ "/bin/sh" ]; then  
    # The file bash.bashrc already sets the default PS1.  
    # PS1='\h:\w\$ '  
    if [ -f /etc/bash.bashrc ]; then  
      . /etc/bash.bashrc  
    fi  
  else  
    if [ "$(id -u)" -eq 0 ]; then  
      PS1='# '  
    else  
      PS1='$ '  
    fi  
  fi  
fi  
  
if [ -d /etc/profile.d ]; then  
  for i in /etc/profile.d/*.sh; do  
    if [ -r $i ]; then  
      . $i  
    fi  
  done  
  unset i  
fi  
  
# Tiempo máximo de sesión: 30 minutos (1800 segundos)  
TMOUT=1800  
readonly TMOUT  
export TMOUT
```

Figura 17. Modificación para tiempo máximo de sesión de 30 minutos.

Si nos conectamos al servidor y estuviéramos sin hacer nada durante 30 minutos, se nos echaría de la sesión.

La medida tres nos pide que si la sesión permanece sin actividad durante 5 minutos, se bloquee. Por eso hemos configurado las siguientes directivas en `/etc/ssh/sshd_config`.



```
admin@iescamp-webserver: ~  
Session Acciones Editar Vista Ayuda  
GNU nano 7.2 /etc/ssh/sshd_config  
#X11DisplayOffset 10  
#X11UseLocalhost yes  
#PermitTTY yes  
PrintMotd no  
#PrintLastLog yes  
#TCPKeepAlive yes  
#PermitUserEnvironment no  
#Compression delayed  
ClientAliveInterval 300  
ClientAliveCountMax 0
```

Figura 18. Adición de las directivas para que se bloquee la sesión después de 5 minutos de inactividad.

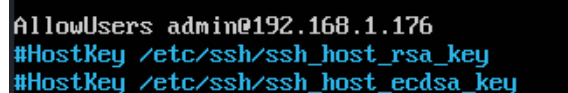
Para comprobar esto, deberíamos conectarnos al servidor y permanecer sin actividad durante 5 minutos. Pasados los 5 minutos, la sesión se hubiera cerrado automáticamente.

Aunque no se ha realizado la prueba empírica por motivos de tiempo, la configuración de `ClientAliveInterval 300` y `TMOUT=1800` garantiza que el comportamiento sería el esperado tras los tiempos indicados.

La siguiente medida para que los usuarios accedan al servicio con certificado la haremos en el apartado 5. Por lo que ahora continuamos con la medida 5, de acceder al servicio solamente con un usuario y desde determinada IP.

Para ello, hemos añadido la directiva de “`AllowUsers`” con un usuario concreto y una IP concreta, en este caso, la IP del cliente Ubuntu.

A partir de este momento, las máquinas tienen otra IP porque las hemos realizado desde otro entorno, con `192.168.1.0/24` en lugar de `192.168.100.0/24`.



```
AllowUsers admin@192.168.1.176  
#HostKey /etc/ssh/ssh_host_rsa_key  
#HostKey /etc/ssh/ssh_host_ecdsa_key
```

Figura 19. Configuración de “AllowUsers”.

Para probar esto, hemos intentado conectarnos desde el cliente Windows, que tiene otra IP (192.168.1.175) y el acceso ha sido rechazado.

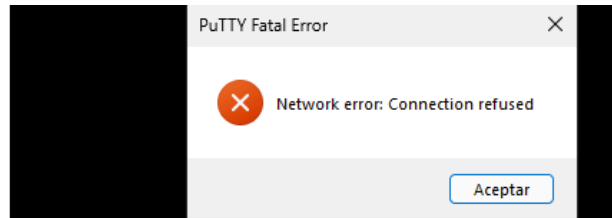


Figura 20. Intento de acceso desde una IP no autorizada.

El siguiente punto nos pide que busquemos la confianza de los equipos en parámetros de filtrado host de SSH en lugar del fichero .rhosts. Para ello hemos configurado el IgnoreRhosts.

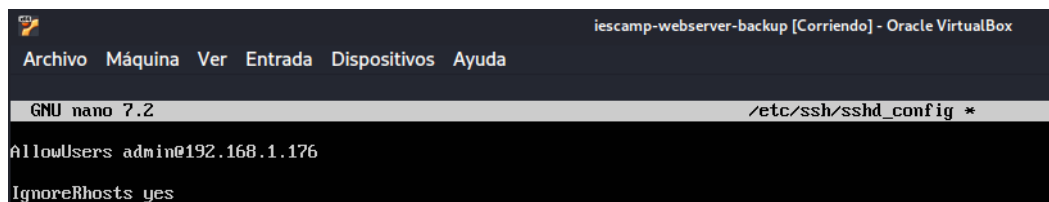


Figura 21. Cambio para ignorar el rhosts y utilizar los parámetros de filtrado host de SSH.

Esto se podría comprobar siguiendo el ejemplo práctico de los contenidos de la unidad.

Después se nos pide que implementemos la versión segura del protocolo. Por supuesto, debemos mantener siempre la versión del servicio SSH totalmente actualizada. En adición a esto, hemos forzado el uso del protocolo SSH versión 2, que es más seguro que la versión 1. Para ello hemos añadido la directiva “Protocol 2”.

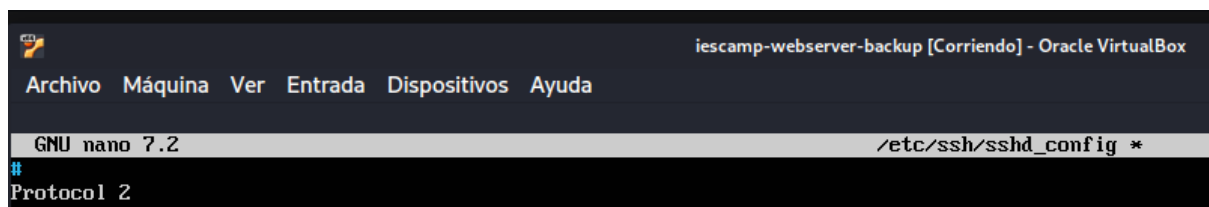
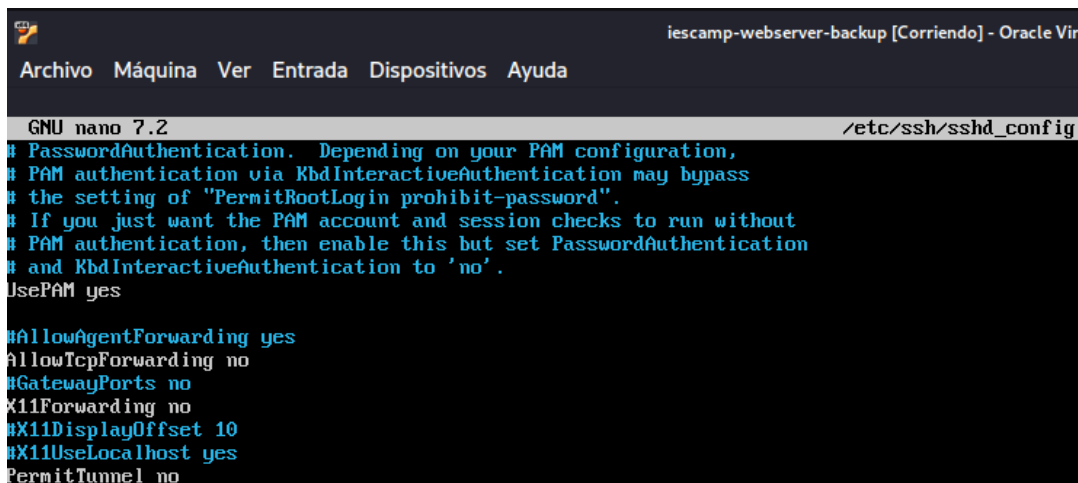


Figura 22. Configuración de Protocol 2.

A continuación, se nos pide que no sea posible que a través del servicio se realice “Post-forwarding” ni “X11 Forwarding”. Por eso hemos deshabilitado todas las formas para evitar posibles túneles que puedan comprometer la seguridad.

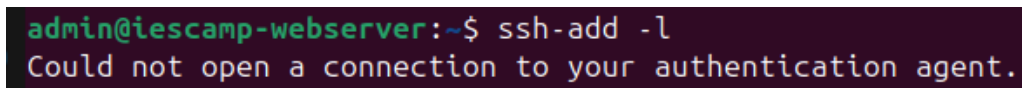


```
iescamp-webserver-backup [Corriendo] - Oracle Vir
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/ssh/sshd_config
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via KbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin prohibit-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes

#AllowAgentForwarding yes
AllowTcpForwarding no
#GatewayPorts no
X11Forwarding no
#X11DisplayOffset 10
#X11UseLocalhost yes
PermitTunnel no
```

Figura 23. Configuración para evitar el forwarding.

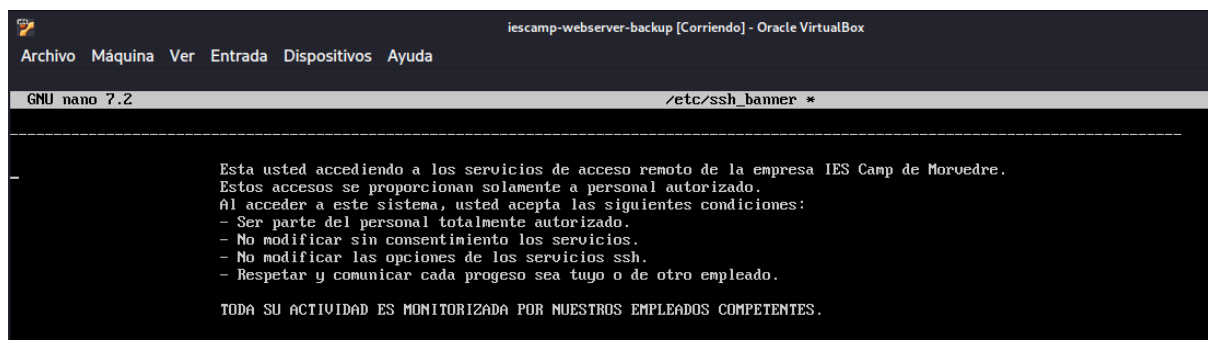
Para comprobar esta medida nos hemos conectado intentando usar agent forwarding y hemos comprobado que no funciona. Es decir, nos hemos podido conectar, pero vemos que no va el agent.



```
admin@iescamp-webserver:~$ ssh-add -l
Could not open a connection to your authentication agent.
```

Figura 24. Comprobación de la prohibición del forwarding.

La medida nueve nos pide que los usuarios reciban en el inicio de sesión un mensaje indicando al tipo de sistema que están accediendo y las obligaciones de cumplir con la normativa interna de la empresa. Por ello, lo primero que debemos hacer es crear un banner personalizado en un archivo llamado /etc/ssh_banner con el texto de advertencia. El que hemos escrito es un texto de prueba.



```
iescamp-webserver-backup [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/ssh_banner *
-----
Esta usted accediendo a los servicios de acceso remoto de la empresa IES Camp de Morvedre.
Estos accesos se proporcionan solamente a personal autorizado.
Al acceder a este sistema, usted acepta las siguientes condiciones:
- Ser parte del personal totalmente autorizado.
- No modificar sin consentimiento los servicios.
- No modificar las opciones de los servicios ssh.
- Respetar y comunicar cada progreso sea tuyo o de otro empleado.

TODA SU ACTIVIDAD ES MONITORIZADA POR NUESTROS EMPLEADOS COMPETENTES.
-----
```

Figura 25. Contenido del archivo de banner /etc/ssh_banner.

Luego hemos activado el banner en la configuración de SSH con la directiva “Banner”, donde le hemos indicado la ubicación del banner que hemos creado.

```
# no default banner path
Banner /etc/ssh_banner
```

Figura 26. Configuración en `sshd_config` para que se muestre el banner.

Al conectarnos al servidor, el mensaje de advertencia se muestra antes de la autenticación.

```
ubuntu@ubuntu2204:~$ ssh -p 22445 -i clienteLinux -L 8080:localhost:80 admin@192.168.1.167
-----
      Esta usted accediendo a los servicios de acceso remoto de la empresa IES Camp
de Morvedre.

      Estos accesos se proporcionan solamente a personal autorizado.
      Al acceder a este sistema, usted acepta las siguientes condiciones:
      - Ser parte del personal totalmente autorizado.
      - No modificar sin consentimiento los servicios.
      - No modificar las opciones de los servicios ssh.
      - Respetar y comunicar cada progreso sea tuyo o de otro empleado.

      TODA SU ACTIVIDAD ES MONITORIZADA POR NUESTROS EMPLEADOS COMPETENTES.
-----
```

Figura 27. Banner mostrado durante la conexión SSH.

Cómo décima medida, se nos pide que se establezcan como protocolo de cifrado SHA2-512, SHA2-256. Para configurarlo, hemos añadido las directivas de MACs, Ciphers y KexAlgorithms con los parámetros correspondientes para los cifrados que se nos piden.

```
iescamp-webserver-backup [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/ssh/sshd_config
# Ciphers and keying
#RekeyLimit default none
MACs hmac-sha2-512,hmac-sha2-256
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes128-gcm@openssh.com
KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org,diffie-hellman-group14-sha256
# Logging
#SyslogFacility AUTH
```

Figura 28. Configuración para que el servidor utilice algoritmos de cifrado fuertes.

Para comprobar esto, hemos intentado acceder al servicio con un algoritmo de cifrado inseguro, como el 3des-cbc, y vemos como el servidor rechaza la conexión.

```
ubuntu@ubuntu2204:~$ ssh -p 22445 -c 3des-cbc admin@192.168.1.167
Unable to negotiate with 192.168.1.167 port 22445: no matching cipher found. Their offer: chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes128-gcm@openssh.com
```

Figura 29. Rechazo de algoritmo de cifrado inseguro.

Por último, se nos pide que activemos los logs del servicio para poder enviárselos al SOC. En nuestro caso, aseguramos que el servicio SSH genera logs con el nivel de detalle adecuado para posteriormente analizarlo con Inav. Para ello configuraremos las directivas “SyslogFacility” y “LogLevel”.

```

lescamp-webserver-backup [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
GNU nano 7.2 /etc/ssh/sshd_config *
# Logging
SyslogFacility AUTH
LogLevel INFO

```

Figura 30. Configuración de logging en `sshd_config`.

Para comprobar esto, tenemos que verificar que los eventos de autenticación se registren correctamente en `/var/log/auth.log`. Para ello, intentaremos acceder de manera errónea al servidor y luego acceder de manera correcta, así veremos distintos logs.

```

2026-02-25T12:30:50.104633+00:00    iscscan-webserver    sshd[503982]: pam_unix(sshd:session): session closed for user admin
2026-02-25T12:31:02.895977+00:00    iscscan-webserver    sshd[504053]: Unable to negotiate with 192.168.1.176 port 42983: no matching cipher found. Their offer: 3des-cbc [preauth]
2026-02-25T12:31:10.431261+00:00    iscscan-webserver    sshd[504055]: User admin from 192.168.1.175 not allowed because not listed in AllowUsers
2026-02-25T12:31:12.478947+00:00    iscscan-webserver    sshd[504055]: pam_unix(sshd:auth): authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.175 user=admin
2026-02-25T12:31:14.940957+00:00    iscscan-webserver    sshd[504055]: Failed password for invalid user admin from 192.168.1.175 port 53440 ssh2
2026-02-25T12:31:19.1364876+00:00    iscscan-webserver    sshd[504055]: Failed password for invalid user admin from 192.168.1.175 port 53440 ssh2
2026-02-25T12:31:21.336764+00:00    iscscan-webserver    sshd[504055]: error: maximum authentication attempts exceeded for invalid user admin from 192.168.1.175 port 53440 ssh2 [preauth]
2026-02-25T12:31:20.436914+00:00    iscscan-webserver    sshd[504055]: Disconnecting invalid user admin 192.168.1.175 port 53440: Too many authentication failures [preauth]
2026-02-25T12:31:20.343693+00:00    iscscan-webserver    sshd[504055]: PAM 1 more authentication failure; logname=uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.175 user=admin
2026-02-25T12:31:46.858266+00:00    iscscan-webserver    sudo:                : TTY=ttul ; PWD=/ ; USER=root ; COMMAND=/usr/bin/grep sshd /var/log/auth.log

```

Figura 31. Comprobación de logs registrados en `/var/log/auth.log`.

Para garantizar que las claves privadas tengan los permisos correctos y que un usuario no pueda manipular las claves de otros, hemos verificado los permisos del archivo `authorized_keys` en el servidor. Hemos ejecutado el comando que muestra el archivo de claves autorizadas, en este caso para nuestro cliente Ubuntu y Windows, su nombre y sus detalles. Podemos ver que los permisos son 600 (-rw-----), lo que significa que solo el propietario (admin) puede leer y escribir el archivo.

[illegible]

Figura 32. Archivo de claves autorizadas con permisos 600 y su contenido.

Podemos comprobar los cambios, si se quiere, verificando los archivos de configuración del servidor ssh. [\[Aquí\]](#) podemos encontrar el archivo con las modificaciones hechas en este apartado, para ver los cambios realizados y todo el archivo de configuración del servidor SSH hasta ahora.

4. Apartado 3.

En este apartado, se nos pide analizar con Inav. Para analizar los archivos de auditoría del sistema, hemos utilizado la herramienta Inav como se nos pide (Log File Navigator), que facilita la visualización y el filtrado de los logs.

Primero, hemos instalado la herramienta en el servidor.

```
admin@iescamp-webserver:/$ sudo apt install lnav
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes NUEVOS:
  lnav
0 actualizados, 1 nuevos se instalarán, 0 para eliminar y 29 no actualizados.
Se necesita descargar 2.797 kB de archivos.
Se utilizarán 8.212 kB de espacio de disco adicional después de esta operación.
Des:1 http://es.archive.ubuntu.com/ubuntu noble/universe amd64 lnav amd64 0.11.2-1build3 [2.797 kB]
Descargados 2.797 kB en 2s (1.156 kB/s)
Seleccionando el paquete lnav previamente no seleccionado.
```

Figura 33. Instalación de Inav en el servidor Ubuntu.

A continuación, hemos ejecutado Inav sobre el archivo de logs de autenticación, con Inav /var/log/auth.log.

Una vez dentro de Inav, hemos filtrado los eventos para mostrar únicamente las líneas relacionadas con el servicio SSH. Para ello, hemos pulsado "/" y hemos escrito ":filter-in sshd".

```

2026-02-24T16:12:04.375 syslog_log.auth.log[0]: sshd[262028]:
2026-02-24T16:12:04.375980+00:00 iesscamp-webserver sshd[262028]: Received signal 15: terminating.
2026-02-24T16:12:04.380660+00:00 iesscamp-webserver sshd[369857]: Server listening on 0.0.0.0 port 22445.
2026-02-24T16:12:04.380705+00:00 iesscamp-webserver sshd[369857]: Server listening on :: port 22445.
2026-02-24T16:18:00.471265+00:00 iesscamp-webserver sudo: admin : TTY=ttty1 ; PWD=/ ; USER=root ; COMMAND=/usr/bin/systemctl start sshd
2026-02-24T16:23:28.383561+00:00 iesscamp-webserver sshd[459573]: Accepted password for admin from 192.168.100.11 port 48364 ssh2
2026-02-24T16:23:28.383939+00:00 iesscamp-webserver sshd[459573]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T16:30:37.773054+00:00 iesscamp-webserver sudo: admin : TTY=ttty1 ; PWD=/ ; USER=root ; COMMAND=/usr/bin/cp /etc/ssh/sshd_config /etc/ssh/sshd_conf
2026-02-24T16:40:09.183197+00:00 iesscamp-webserver sshd[459655]: Received disconnect from 192.168.100.11 port 48364:11: disconnected by user
2026-02-24T16:40:09.187739+00:00 iesscamp-webserver sshd[459655]: Disconnected from user admin 192.168.100.11 port 48364
2026-02-24T16:40:09.188352+00:00 iesscamp-webserver sshd[459573]: pan_unix(sshd:session): session closed for user admin
2026-02-24T16:42:10.226921+00:00 iesscamp-webserver sshd[459772]: Connection closed by authenticating user admin 192.168.100.169 port 44980 [preauth]
2026-02-24T16:42:10.471882+00:00 iesscamp-webserver sshd[459774]: Connection closed by authenticating user admin 192.168.100.169 port 33328 [preauth]
2026-02-24T16:42:13.376342+00:00 iesscamp-webserver sshd[459776]: Accepted password for admin from 192.168.100.169 port 33340 ssh2
2026-02-24T16:42:13.379878+00:00 iesscamp-webserver sshd[459776]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T16:42:13.855583+00:00 iesscamp-webserver sshd[459834]: Received disconnect from 192.168.100.169 port 33340:11: disconnected by user
2026-02-24T16:42:13.855900+00:00 iesscamp-webserver sshd[459834]: Disconnected from user admin 192.168.100.169 port 33340
2026-02-24T16:43:02.955660+00:00 iesscamp-webserver sshd[459840]: Accepted password for admin from 192.168.100.169 port 43028 ssh2: RSA SHA256:hCpu9FenquZXHJh
2026-02-24T16:43:02.959117+00:00 iesscamp-webserver sshd[459840]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T17:48:45.031723+00:00 iesscamp-webserver sshd[459945]: Accepted password for admin from 192.168.100.172 port 50102 ssh2
2026-02-24T17:48:45.041532+00:00 iesscamp-webserver sshd[459945]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T17:49:15.760158+00:00 iesscamp-webserver sshd[460025]: Received disconnect from 192.168.100.172 port 50102:11: disconnected by user
2026-02-24T17:49:15.770929+00:00 iesscamp-webserver sshd[460025]: Disconnected from user admin 192.168.100.172 port 50102
2026-02-24T17:49:15.771693+00:00 iesscamp-webserver sshd[459945]: pan_unix(sshd:session): session closed for user admin
2026-02-24T17:56:52.082032+00:00 iesscamp-webserver sshd[460046]: Accepted password for admin from 192.168.100.172 port 50156 ssh2
2026-02-24T17:56:52.084963+00:00 iesscamp-webserver sshd[460046]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T17:56:52.784253+00:00 iesscamp-webserver sshd[460117]: Received disconnect from 192.168.100.172 port 50156:11: disconnected by user
2026-02-24T17:56:52.784330+00:00 iesscamp-webserver sshd[460046]: pan_unix(sshd:session): session closed for user admin
2026-02-24T17:57:23.281865+00:00 iesscamp-webserver sshd[460121]: Accepted publickey for admin from 192.168.100.172 port 50158 ssh2: ED25519 SHA256:Xo2luUMiuxm
2026-02-24T17:57:23.284799+00:00 iesscamp-webserver sshd[460121]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T17:57:38.490394+00:00 iesscamp-webserver sshd[460169]: Received disconnect from 192.168.100.172 port 50158:11: disconnected by user
2026-02-24T17:57:38.490650+00:00 iesscamp-webserver sshd[460169]: Disconnected from user admin 192.168.100.172 port 50158
2026-02-24T17:57:39.491224+00:00 iesscamp-webserver sshd[460121]: pan_unix(sshd:session): session closed for user admin
2026-02-24T18:02:31.516773+00:00 iesscamp-webserver sshd[460187]: Accepted password for admin from 192.168.100.172 port 57295 ssh2
2026-02-24T18:02:31.516773+00:00 iesscamp-webserver sshd[460187]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T18:02:31.516773+00:00 iesscamp-webserver sshd[460259]: Accepted publickey for admin from 192.168.100.172 port 51392 ssh2: ED25519 SHA256:Xo2luUMiuxm
2026-02-24T18:06.947800+00:00 iesscamp-webserver sshd[460259]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T18:11:03.110169+00:00 iesscamp-webserver sshd[460259]: pan_unix(sshd:session): session closed for user admin
2026-02-24T18:11:05.884245+00:00 iesscamp-webserver sshd[460187]: pan_unix(sshd:session): session closed for user admin
2026-02-24T18:13:20.676434+00:00 iesscamp-webserver sshd[262044]: pan_unix(sshd:session): session closed for user admin
2026-02-24T18:13:49.288558+00:00 iesscamp-webserver sshd[460330]: Accepted password for admin from 192.168.100.11 port 57960 ssh2
2026-02-24T18:13:49.294772+00:00 iesscamp-webserver sshd[460330]: pan_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-24T18:14:09.313094+00:00 iesscamp-webserver sudo: admin : TTY=pts/0 ; PWD=/home/admin ; USER=root ; COMMAND=/usr/bin/nano /etc/ssh/sshd_config
2026-02-24T18:16:00.445187+00:00 iesscamp-webserver sudo: admin : TTY=pts/0 ; PWD=/home/admin ; USER=root ; COMMAND=/usr/bin/nano /etc/ssh/sshd_config

```

Figura 34. Filtrado de logs para mostrar solo eventos de sshd en Inav.

Se nos piden tres cosas en la práctica:

- Filtrar los ficheros de auditoría para que solo muestre los eventos de accesos por SSH (:filter-in sshd).
- Buscar si se ha producido un intento de acceso no identificable.
- Intentar reproducir la línea del tiempo de un acceso.

El primer punto, lo hemos solucionado anteriormente filtrando los contenidos de sshd. La segunda petición, buscando “/failed” hemos encontrado bastantes accesos fallidos al servidor.

Hemos encontrado intentos de acceso como root, que habíamos hecho para comprobar que funcionarían las medidas anteriores. Por lo que, hemos encontrado intentos fallidos para el usuario root desde diferentes IPs, en un caso real esto podría significar un intento de ataque de fuerza bruta hacia el root.

Y, en el mismo log, se ve errores de contraseña para el usuario admin desde la IP 192.168.1.176, puede ser errores humanos, o también un ataque de fuerza bruta desde una IP autorizada.

```

Preview Data: Matching lines for search
Press CTRL+P to s
L 46: 2026-02-24T18:19:38.388529+00:00 iescamp-webserver sshd(460432): Failed password for root from 192.168.100.11 port 44790 ssh2
L 52: 2026-02-24T18:20:49.107617+00:00 iescamp-webserver sshd(460442): Failed password for root from 192.168.100.169 port 38534 ssh2
L 53: 2026-02-24T18:20:53.028272+00:00 iescamp-webserver sshd(460442): Failed password for root from 192.168.100.169 port 38534 ssh2
L209: 2026-02-25T11:53:51.708548+00:00 iescamp-webserver sshd(502974): Failed password for invalid user admin from 192.168.1.176 port 41288 ssh2
L214: 2026-02-25T11:54:10.634039+00:00 iescamp-webserver sshd(502977): Failed password for invalid user admin from 192.168.1.176 port 34524 ssh2
L228: 2026-02-25T11:55:41.266302+00:00 iescamp-webserver sshd(503101): Failed password for invalid user admin from 192.168.1.175 port 56225 ssh2
L229: 2026-02-25T11:55:47.370345+00:00 iescamp-webserver sshd(503101): Failed password for invalid user admin from 192.168.1.175 port 56225 ssh2
L235: 2026-02-25T11:56:07.228553+00:00 iescamp-webserver sshd(503104): Failed password for invalid user admin from 192.168.1.175 port 56238 ssh2
L241: 2026-02-25T11:56:57.734685+00:00 iescamp-webserver sshd(503177): Failed password for invalid user admin from 192.168.1.175 port 57290 ssh2
L244: 2026-02-25T11:57:30.900270+00:00 iescamp-webserver sshd(503180): Failed password for invalid user admin from 192.168.1.175 port 49170 ssh2
Search for: (Press CTRL+J to jump to a previous hit and CTRL+I to abort)
/failed
4

```

Figura 35. Detección de intentos de acceso como root y admin en los logs.

También, con el parámetro “/invalid user”, hemos observado intentos de acceso con el usuario admin desde una IP no autorizada, 192.168.1.175. Lo que en este caso también fue una prueba para demostrar las medidas del apartado anterior. Se puede ver que el servidor ha rechazado estos accesos y los ha registrado correctamente. En un caso real, esto también podría verse como un intento de ataque desde IPs no incluidas en nuestra directiva “AllowUsers”.

```

L209: 2026-02-25T11:53:51.708548+00:00 iescamp-webserver sshd(502974): Failed password for invalid user admin from 192.168.1.176 port 41288 ssh2
L210: 2026-02-25T11:53:52.539570+00:00 iescamp-webserver sshd(502974): error: maximum authentication attempts exceeded for invalid user admin from 192.168.1.17
L211: 2026-02-25T11:53:52.539724+00:00 iescamp-webserver sshd(502974): Disconnecting invalid user admin 192.168.1.176 port 41288: Too many authentication failu
L214: 2026-02-25T11:54:10.634039+00:00 iescamp-webserver sshd(502977): Failed password for invalid user admin from 192.168.1.176 port 34524 ssh2
L215: 2026-02-25T11:54:11.525140+00:00 iescamp-webserver sshd(502977): error: maximum authentication attempts exceeded for invalid user admin from 192.168.1.17
Search for: (Press CTRL+J to jump to a previous hit and CTRL+I to abort)
/invalid user_
4

```

Figura 36. Intento de acceso desde una IP no autorizada

Además, hemos visto conexiones que se han cerrado por superar el número máximo de intentos de autenticación, con “/preauth”, lo que demuestra que la directiva “MaxAuthTries” está funcionando. Preauth indica que la conexión fue cerrada por el servidor antes de que el cliente se autentique exitosamente.

```

Preview Data: Matching lines for search
Press CTRL+P to show/hide
L 47: 2026-02-24T18:19:43.922427+00:00 iescamp-webserver sshd(460432): Connection closed by authenticating user root 192.168.100.11 port 44790 [preauth]
L 54: 2026-02-24T18:20:53.037529+00:00 iescamp-webserver sshd(460442): error: maximum authentication attempts exceeded for root from 192.168.100.169 port 38534
L 55: 2026-02-24T18:20:53.037810+00:00 iescamp-webserver sshd(460442): Disconnecting authenticating user root 192.168.100.169 port 38534: Too many authenticati
L 67: 2026-02-24T18:28:17.597285+00:00 iescamp-webserver sshd(460536): Connection closed by authenticating user root 192.168.100.11 port 46516 [preauth]
L 68: 2026-02-24T18:28:43.655159+00:00 iescamp-webserver sshd(460538): Connection closed by authenticating user root 192.168.100.169 port 55416 [preauth]
L 69: 2026-02-24T18:29:00.382307+00:00 iescamp-webserver sshd(460540): Connection closed by authenticating user admin 192.168.100.11 port 57258 [preauth]
L 70: 2026-02-24T18:29:13.904749+00:00 iescamp-webserver sshd(460542): Connection closed by authenticating user admin 192.168.100.169 port 57224 [preauth]
L 71: 2026-02-24T18:29:15.856410+00:00 iescamp-webserver sshd(460544): Connection closed by authenticating user admin 192.168.100.169 port 60546 [preauth]
L 72: 2026-02-24T18:29:16.925766+00:00 iescamp-webserver sshd(460546): Connection closed by authenticating user admin 192.168.100.169 port 60558 [preauth]
L 74: 2026-02-24T18:30:01.824704+00:00 iescamp-webserver sshd(460541): Connection closed by authenticating user admin 192.168.100.169 port 44156 [preauth]
Search for: (Press CTRL+J to jump to a previous hit and CTRL+I to abort)
/preauth_
4

```

Figura 37. Registros de exceso de autenticaciones.

El último punto de este apartado, nos pide que reconstruyamos la línea del tiempo de un acceso. Para ello, hemos seleccionado un acceso exitoso, la secuencia que hemos observado es:

- Aceptación de la clave pública.
- Apertura de una sesión para el usuario admin.
- El usuario se desconecta y la sesión se cierra.

```
2026-02-25T12:41:15.165482+00:00 iescamp-webserver sshd[5048701]: accepted publickey for admin from 192.168.1.176 port 33824 ssh2: RSA SHA256:hCpu9Fenqu2XBjndf
2026-02-25T12:41:15.167186+00:00 iescamp-webserver sshd[5048701]: pam_unix(sshd:session): session opened for user admin(uid=1000) by admin(uid=0)
2026-02-25T12:42:00.317295+00:00 iescamp-webserver sshd[5049281]: Received disconnect from 192.168.1.176 port 33824:11: disconnected by user
2026-02-25T12:42:00.317434+00:00 iescamp-webserver sshd[5049281]: Disconnected from user admin 192.168.1.176 port 33824
2026-02-25T12:42:00.318992+00:00 iescamp-webserver sshd[5048701]: pam_unix(sshd:session): session closed for user admin
```

Figura 38. Línea del tiempo completa de un acceso exitoso.

Esta secuencia nos permite trazar las acciones de un usuario desde que se conecta hasta que se desconecta, lo cual es muy útil para auditorías de seguridad.

5. Apartado 4.

En esta parte del documento, vamos a observar y comparar si se ha incrementado la seguridad del servidor con lynis. Con esto, comprobaremos si las medidas de seguridad implementadas han mejorado la protección del servidor. He hecho tres auditorías, una al comenzar, otra al implantar las medidas del apartado 2, y la última al terminar toda la práctica.

Hemos ejecutado la primera auditoría el 24 de febrero de 2026, antes de realizar cualquier cambio en la configuración de SSH, el archivo completo podemos encontrarlo [\[aquí\]](#). El resultado de esta auditoría se ha guardado en el archivo iescamp-webserver-24022026-Audit-Ini.dat, y tiene un índice de hardening de 64.

La segunda auditoría, fue realizada con las medidas implementadas en el apartado 3, el 25 de febrero de 2026, cuyo contenido podemos encontrar [\[aquí\]](#). El resultado de esta auditoría se ha guardado en el archivo iescamp-webserver-25022026-Audit-MedidasSin4.dat, y tiene un índice de hardening de 64.

Después de implementar todas las medidas de seguridad descritas en todo el documento, hasta el apartado 6, hemos ejecutado una última auditoría el 25 de febrero de 2026 también, podemos encontrar todo el resultado [\[aquí\]](#). El resultado de esta auditoría se ha guardado en el archivo iescamp-webserver-25022026-Audit-Final.dat, y tiene un índice de hardening de 64.

Aunque el índice número se ha mantenido en 64, hemos observado algunas mejoras importantes:

- Timeout de sesión, en la auditoría primera de lynis estaba como “session_timeout_enabled=0” sin configurar. En la última auditoría estaba

como “session_timeout_enabled=1”, ya que la hemos configurado en el apartado 2 con 30 minutos.

- También se nos muestra que antes no estaba el fail2ban que es una medida que nos propone el lynis, en el apartado 6 la instalamos.
- Además, se nos menciona en la final que el “pam_google_authenticator.so” está presente. Cosa que también implementamos en el apartado 6.
- Por último, en la inicial nos hacía muchas sugerencias, y en la última sólo persisten “LogLevel”, “MaxSessions” y “TCPKeepAlive”.

En la auditoría inicial, lynis nos mostraba varias sugerencias relacionadas con SSH. Sin embargo, al final, la mayoría de estas sugerencias han desaparecido, lo que confirma que nuestras configuraciones han sido efectivas.

```
suggestion[]=SSH-7408|Consider hardening SSH configuration|AllowTcpForwarding (set YES to NO)|-|
details[]=SSH-7408|sshd|desc:sshd option
AllowTcpForwarding;field:AllowTcpForwarding;prefval:NO;value:YES;|
suggestion[]=SSH-7408|Consider hardening SSH configuration|ClientAliveCountMax (set 3 to 2)|-|
details[]=SSH-7408|sshd|desc:sshd option
ClientAliveCountMax;field:ClientAliveCountMax;prefval:2;value:3;|
suggestion[]=SSH-7408|Consider hardening SSH configuration|LogLevel (set INFO to VERBOSE)|-|
details[]=SSH-7408|sshd|desc:sshd option
LogLevel;field:LogLevel;prefval:VERBOSE;value:INFO;|
suggestion[]=SSH-7408|Consider hardening SSH configuration|MaxSessions (set 10 to 2)|-|
details[]=SSH-7408|sshd|desc:sshd option
MaxSessions;field:MaxSessions;prefval:2;value:10;|
suggestion[]=SSH-7408|Consider hardening SSH configuration|TCPKeepAlive (set YES to NO)|-|
details[]=SSH-7408|sshd|desc:sshd option
TCPKeepAlive;field:TCPKeepAlive;prefval:NO;value:YES;|
suggestion[]=SSH-7408|Consider hardening SSH configuration|X11Forwarding (set YES to NO)|-|
details[]=SSH-7408|sshd|desc:sshd option
X11Forwarding;field:X11Forwarding;prefval:NO;value:YES;|
suggestion[]=SSH-7408|Consider hardening SSH configuration|AllowAgentForwarding (set YES to NO)|-|
details[]=SSH-7408|sshd|desc:sshd option
AllowAgentForwarding;field:AllowAgentForwarding;prefval:NO;value:YES;|
```

Figura 39. Sugerencias de lynis en la primera auditoría.

```
suggestion[]=SSH-7408|Consider hardening SSH configuration|LogLevel (set INFO to  
VERBOSE)|-|  
details[]=SSH-7408|sshd|desc:sshd option  
LogLevel;field:LogLevel;prefval:VERBOSE;value:INFO;|  
suggestion[]=SSH-7408|Consider hardening SSH configuration|MaxSessions (set 10 to  
2)|-|  
details[]=SSH-7408|sshd|desc:sshd option  
MaxSessions;field:MaxSessions;prefval:2;value:10;|  
suggestion[]=SSH-7408|Consider hardening SSH configuration|TCPKeepAlive (set YES to  
NO)|-|  
details[]=SSH-7408|sshd|desc:sshd option  
TCPKeepAlive;field:TCPKeepAlive;prefval:NO;value:YES;|
```

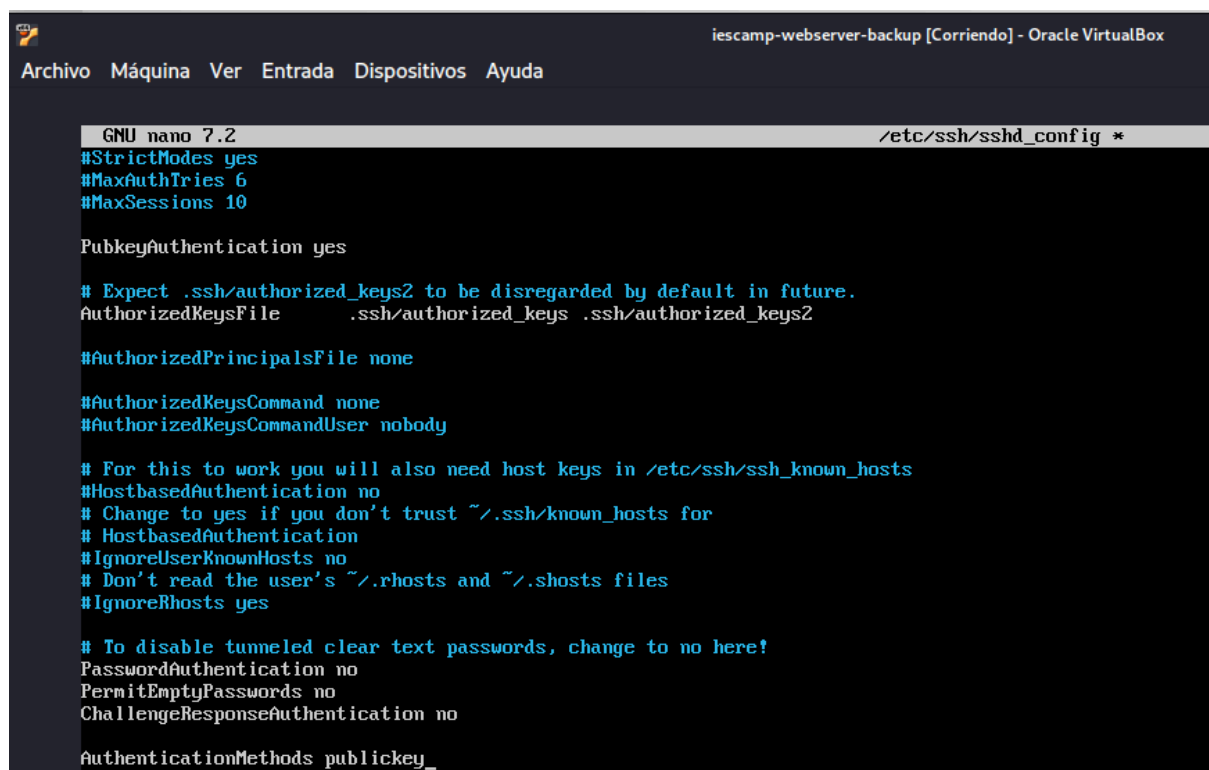
Figura 40. Sugerencias de lynis en la última auditoría.

Aunque el índice de hardening se ha mantenido, hemos mejorado la seguridad real del servidor SSH.

6. Apartado 5.

Este apartado corresponde a la medida 4 de seguridad, que establece que los usuarios deban acceder al servicio SSH con un certificado.

Lo primero que hemos hecho ha sido modificar el archivo `/etc/ssh/sshd_config` con las siguientes directivas:



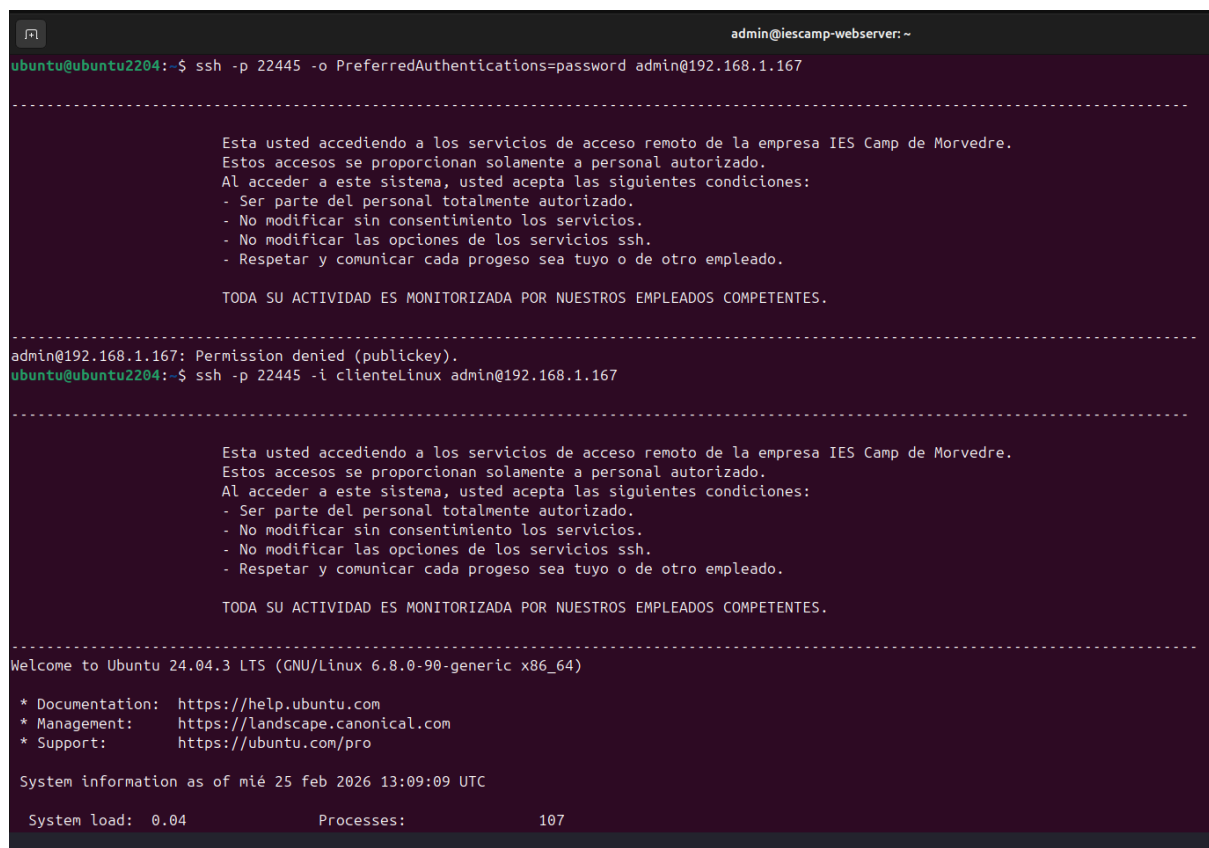
The screenshot shows a terminal window titled "iescamp-webserver-backup [Corriendo] - Oracle VirtualBox". The terminal is running the nano text editor on the file `/etc/ssh/sshd_config`. The configuration shown is as follows:

```
GNU nano 7.2 /etc/ssh/sshd_config *  
#StrictModes yes  
#MaxAuthTries 6  
#MaxSessions 10  
  
PubkeyAuthentication yes  
  
# Expect .ssh/authorized_keys2 to be disregarded by default in future.  
AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2  
  
#AuthorizedPrincipalsFile none  
  
#AuthorizedKeysCommand none  
#AuthorizedKeysCommandUser nobody  
  
# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts  
#HostbasedAuthentication no  
# Change to yes if you don't trust ~/.ssh/known_hosts for  
# HostbasedAuthentication  
#IgnoreUserKnownHosts no  
# Don't read the user's ~/.rhosts and ~/.shosts files  
#IgnoreRhosts yes  
  
# To disable tunneled clear text passwords, change to no here!  
PasswordAuthentication no  
PermitEmptyPasswords no  
ChallengeResponseAuthentication no  
  
AuthenticationMethods publickey_
```

Figura 41. Configuración de autenticación en `/etc/ssh/sshd_config`.

Para comprobar que funciona, hemos forzado la autenticación por contraseña, que es el método inseguro que queremos eliminar, con el comando “ssh -p 22445 -o PreferredAuthentications=password admin@192.168.1.167”. Y vemos que el servidor nos ha rechazado la conexión con el mensaje “Permission denied (publickey)”, sin llegar a solicitar la contraseña.

Luego hemos accedido al servidor con nuestra clave privada con el comando “ssh -p 22445 -i clienteLinux admin@192.168.1.167”, y vemos que la conexión se ha establecido correctamente.



```
admin@iescamp-webserver: ~  
ubuntu@ubuntu2204:~$ ssh -p 22445 -o PreferredAuthentications=password admin@192.168.1.167  
-----  
Esta usted accediendo a los servicios de acceso remoto de la empresa IES Camp de Morvedre.  
Estos accesos se proporcionan solamente a personal autorizado.  
Al acceder a este sistema, usted acepta las siguientes condiciones:  
- Ser parte del personal totalmente autorizado.  
- No modificar sin consentimiento los servicios.  
- No modificar las opciones de los servicios ssh.  
- Respetar y comunicar cada progreso sea tuyo o de otro empleado.  
  
TODA SU ACTIVIDAD ES MONITORIZADA POR NUESTROS EMPLEADOS COMPETENTES.  
-----  
admin@192.168.1.167: Permission denied (publickey).  
ubuntu@ubuntu2204:~$ ssh -p 22445 -i clienteLinux admin@192.168.1.167  
-----  
Esta usted accediendo a los servicios de acceso remoto de la empresa IES Camp de Morvedre.  
Estos accesos se proporcionan solamente a personal autorizado.  
Al acceder a este sistema, usted acepta las siguientes condiciones:  
- Ser parte del personal totalmente autorizado.  
- No modificar sin consentimiento los servicios.  
- No modificar las opciones de los servicios ssh.  
- Respetar y comunicar cada progreso sea tuyo o de otro empleado.  
  
TODA SU ACTIVIDAD ES MONITORIZADA POR NUESTROS EMPLEADOS COMPETENTES.  
-----  
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.8.0-90-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
System information as of mié 25 feb 2026 13:09:09 UTC  
  
System load:  0.04          Processes:      107
```

Figura 42. Pruebas de conexiones con contraseña y con certificado.

Con estas configuraciones y pruebas, hemos verificado que el acceso al servicio SSH se realiza exclusivamente mediante un certificado (clave pública).

7. Apartado 6.

En este apartado hemos implementado algunas medidas adicionales de fortificación SSH basadas en estándares, guías y políticas de securización reconocidas, que no se han visto en el aula. Todas ellas aumentan la robustez del servidor.

Una de las medidas que vamos implementar es fail2ban. Es un sistema de prevención de intrusiones que monitoriza los logs y bloquea proactivamente las direcciones IP que muestran comportamientos maliciosos, como múltiples fallos de autenticación en un corto periodo de tiempo.

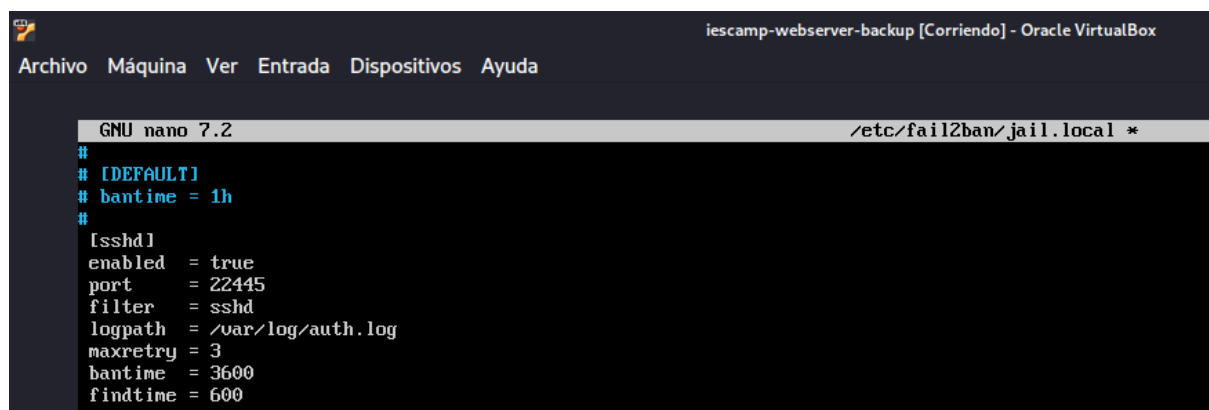
Se alinea con los estándares de CIS Benchmark (Debian Family) y NIST SP 800-53.

- CIS Benchmark: recomendación DEB-0880 "Install fail2ban to automatically ban hosts that commit multiple authentication errors".
- NIST SP 800-53: control AC-7 (Unsuccessful Logon Attempts) sobre limitación de intentos de conexión fallidos.

Hemos instalado fail2ban y configurado una jaula específica para SSH en el puerto 22445.

```
admin@iescamp-webserver:~$ sudo apt install fail2ban
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se instalarán los siguientes paquetes adicionales:
python3-pyasyncore python3-pyinotify whois
Paquetes sugeridos:
mailx monit sqlite3 python-pyinotify-doc
Se instalarán los siguientes paquetes NUEVOS:
fail2ban python3-pyasyncore python3-pyinotify whois
0 actualizados, 4 nuevos se instalarán, 0 para eliminar y 29 no actualizados.
Se necesita descargar 496 kB de archivos.
Se utilizarán 2.572 kB de espacio de disco adicional después de esta operación.
¿Desea continuar? [S/n]
```

Figura 43. Instalación de fail2ban.



```
iescamp-webserver-backup [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

GNU nano 7.2 /etc/fail2ban/jail.local *
#
# [DEFAULT]
# bantime = 1h
#
[sshd]
enabled = true
port = 22445
filter = sshd
logpath = /var/log/auth.log
maxretry = 3
bantime = 3600
findtime = 600
#
```

Figura 44. Configuración de la jaula para SSH en /etc/fail2ban/jail.local

Los parámetros que hemos configurado son:

- Maxretry para establecer tres intentos fallidos.

- Bantime para bloquearlo durante una hora (3600 segundos).
- Findtime para darle una ventana de 10 minutos para contar los intentos.

Hemos verificado que el servicio está funcionando correctamente.

```
admin@iescamp-webserver:~$ sudo systemctl enable --now fail2ban
Synchronizing state of fail2ban.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable fail2ban
admin@iescamp-webserver:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed: 0
| `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
  |- Currently banned: 0
  |- Total banned: 0
  `-- Banned IP list:
admin@iescamp-webserver:~$ _
```

Figura 45. Verificación del estado de la jaula sshd en fail2ban.

Luego hemos fallado unas veces para que se vea que está correctamente en funcionamiento.

```
admin@iescamp-webserver:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 1
| |- Total failed: 3
| `-- Journal matches: _SYSTEMD_UNIT=sshd.service + _COMM=sshd
`- Actions
  |- Currently banned: 0
  |- Total banned: 0
  `-- Banned IP list:
```

Figura 46. Verificación del estado de la jaula sshd en fail2ban con intentos fallidos.

Después, hemos implementado, a parte de solo poder iniciar sesión con certificado, una autenticación de dos factores como medida adicional. Esta medida añade una segunda capa de seguridad, además de la clave SSH, se requiere un código de un solo uso (TOTP) generado por una aplicación en el teléfono del administrador.

Se alinea con los estándares de NIST SP 800-63B (Digital Identity Guidelines y prácticas recomendadas por CISA.

- NIST SP 800-63B: recomienda el uso de autenticación multifactor para mitigar el robo de credenciales.
- CISA: el uso de MFA es una de las medidas más efectivas para proteger el acceso remoto.

Hemos modificado el archivo `/etc/ssh/sshd_config` con las medidas para tener un doble factor de autenticación mediante google authenticator.

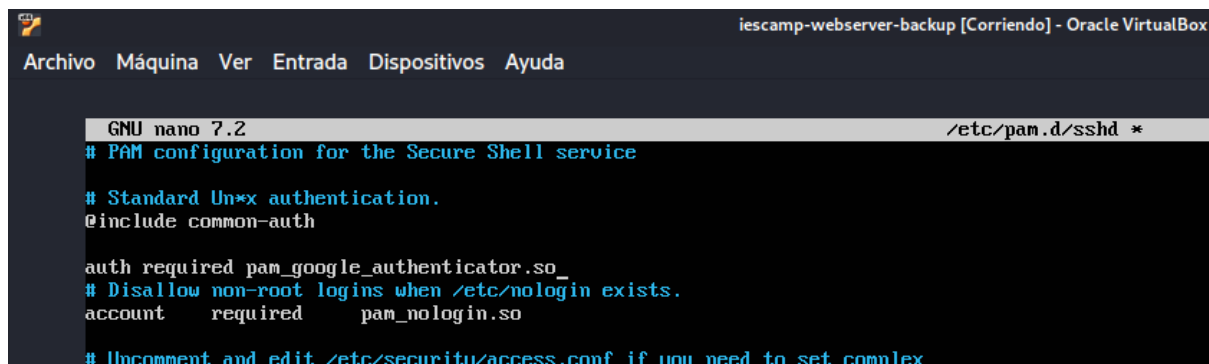
```
ChallengeResponseAuthentication yes

AuthenticationMethods publickey,keyboard-interactive
# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication yes

# Kerberos options
#KerberosAuthentication no
```

Figura 47. Configuración de autenticación multifactor.

Además, hemos modificado el archivo PAM para requerir el módulo de google authenticator:



```
iescamp-webserver-backup [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

GNU nano 7.2 /etc/pam.d/sshd *
# PAM configuration for the Secure Shell service

# Standard Unix authentication.
@include common-auth

auth required pam_google_authenticator.so_
# Disallow non-root logins when /etc/nologin exists.
account required pam_nologin.so

# Uncomment and edit /etc/security/access.conf if you need to set complex
```

Figura 48. Modificación de `/etc/pam.d/ssh`.

Hemos instalado el paquete “libpam-google-authenticator” que nos hará falta para que funcione. Luego, hemos ejecutado el comando para configurar google authenticator con el servidor.

```
Your new secret key is: CLB7S2GFHL4NYVHYD3I5TRJDDI
Enter code from app (-1 to skip): 881479
Code confirmed
Your emergency scratch codes are:
 60520941
 44815805
 54272313
 35096757
 66954594

Do you want me to update your "/home/admin/.google_authenticator" file? (y/n)
```

Figura 49. Configuración inicial de google authenticator para el usuario.

Cuando hemos intentado acceder, se nos pide el código de verificación de google authenticator.

```
(admin@192.168.1.167) Password:  
(admin@192.168.1.167) Verification code:
```

Figura 50. Conexión exitosa que requiere clave SSH y código 2FA.

Otra medida que hemos implementado para este apartado es un entorno chroot para los usuarios de SFTP, de manera que queden encerrados en su directorio personal y no puedan navegar por el resto del sistema de archivos del servidor.

Se alinea con los estándares del principio de mínimo privilegio (NIST SP 800-53, Control AC-6) y las guías de hardening de SSH.

- Principio de mínimo privilegio: “Emplear el principio de mínimo privilegio, permitiendo a los usuarios solo los accesos necesarios para realizar sus tareas”.
- Guías hardening SSH: práctica común aislar entornos de transferencia de archivos.

Primero, hemos creado un grupo para los usuarios SFTP y hemos metido al usuario “admin” en él.

```
admin@iescamp-webserver:~$ sudo groupadd sftponly  
admin@iescamp-webserver:~$ sudo usermod -aG sftponly usuariosftp  
usermod: user 'usuariosftp' does not exist  
admin@iescamp-webserver:~$ sudo usermod -aG sftponly admin
```

Figura 51. Creación del grupo sftponly y asignación de usuario.

Luego, hemos añadido la siguiente configuración al final de /etc/ssh/sshd_config para garantizar el enjaulamiento:

```
Match Group sftponly  
    ChrootDirectory /home/%u  
    AllowTCPForwarding no  
    X11Forwarding no  
    ForceCommand internal-sftp
```

Figura 52. Configuración de chrootDirectory para el grupo sftponly.

Por último, hemos decidido utilizar la herramienta ssh-audit para analizar la configuración de nuestro servidor SSH desde el punto de vista de un cliente, obteniendo un informe detallado sobre algoritmos soportados.

Se alinea con los estándares de NIST SP 800-115 (Technical Guide to Information Security Testing).

- NIST SP 800-115: recomienda el uso de herramientas de escaneo de vulnerabilidades para identificar debilidades en las configuraciones de los sistemas.

Hemos instalado la herramienta con “sudo apt install ssh-audit” y la hemos ejecutado contra el servidor local:

```
admin@iescamp-webserver:~$ ssh-audit localhost -p 22445
# general
(gen) banner: SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.14
(gen) software: OpenSSH 9.6p1
(gen) compatibility: OpenSSH 7.4+, Dropbear SSH 2018.76+
(gen) compression: enabled (zlib@openssh.com)

# key exchange algorithms
(key) curve25519-sha256 -- [info] available since OpenSSH 7.4, Dropbear SSH 2018.76
-- [info] default key exchange since OpenSSH 6.4
(key) curve25519-sha256@libssh.org -- [info] available since OpenSSH 6.4, Dropbear SSH 2013.62
-- [info] default key exchange since OpenSSH 6.4
(key) diffie-hellman-group14-sha256 -- [warn] 2048-bit modulus only provides 112-bits of symmetric strength
-- [info] available since OpenSSH 7.3, Dropbear SSH 2016.73
(key) ext-info-s -- [info] pseudo-algorithm that denotes the peer supports RFC8308 extensions
(key) kex-strict-s-v00@openssh.com -- [info] pseudo-algorithm that denotes the peer supports a stricter key exchange method as a counter-measure
(95)

# host-key algorithms
(key) rsa-sha2-512 (3072-bit) -- [info] available since OpenSSH 7.2
(key) rsa-sha2-256 (3072-bit) -- [info] available since OpenSSH 7.2
(key) ecdsa-sha2-nistp256 -- [fail] using elliptic curves that are suspected as being backdoored by the U.S. National Security Agency
-- [warn] using weak random number generator could reveal the key
-- [info] available since OpenSSH 5.7, Dropbear SSH 2013.62
(key) ssh-ed25519 -- [info] available since OpenSSH 6.5

# encryption algorithms (ciphers)
(enc) chacha20-poly1305@openssh.com -- [info] available since OpenSSH 6.5
-- [info] default cipher since OpenSSH 6.9
(enc) aes256-gcm@openssh.com -- [info] available since OpenSSH 6.2
(enc) aes128-gcm@openssh.com -- [info] available since OpenSSH 6.2

# message authentication code algorithms
(mac) hmac-sha2-512 -- [warn] using encrypt-and-MAC mode
-- [info] available since OpenSSH 5.9, Dropbear SSH 2013.56
(mac) hmac-sha2-256 -- [warn] using encrypt-and-MAC mode
-- [info] available since OpenSSH 5.9, Dropbear SSH 2013.56
```

Figura 53. Resultados de ssh-audit (parte 1).

```
# fingerprints
(fin) ssh-ed25519: SHA256:CItnjNtaNhJiiE9suFmhWYtCEAmD5kJPbzx3h7yv6s
(fin) ssh-rsa: SHA256:lNoMF8nr8goEAaNosyB4q3gm8WzFPSkXwhnfn7Uy2Yg

# algorithm recommendations (for OpenSSH 9.6)
(rec) -ecdsa-sha2-nistp256 -- key algorithm to remove
(rec) +aes128-ctr -- enc algorithm to append
(rec) +aes192-ctr -- enc algorithm to append
(rec) +aes256-ctr -- enc algorithm to append
(rec) +diffie-hellman-group-exchange-sha256 -- kex algorithm to append
(rec) +diffie-hellman-group16-sha512 -- kex algorithm to append
(rec) +diffie-hellman-group18-sha512 -- kex algorithm to append
(rec) +sntrup761x25519-sha512@openssh.com -- kex algorithm to append
(rec) -diffie-hellman-group14-sha256 -- kex algorithm to remove
(rec) -hmac-sha2-256 -- mac algorithm to remove
(rec) -hmac-sha2-512 -- mac algorithm to remove

# additional info
(nfo) For hardening guides on common OSes, please see: <https://www.ssh-audit.com/hardening_guides.html>
(nfo) Be aware that, while this target properly supports the strict key exchange method (via the kex-strict-v00@openssh.com), all peers must also support this feature as well, otherwise the vulnerability will still be present; these MACs are fine while paired with non-CBC cipher types.
```

Figura 54. Resultados de ssh-audit (parte 2).

El informe ha confirmado que los algoritmos que hemos configurado son seguros y nos ha recomendado, adicionalmente, eliminar ecdsa-sha2-nistp256 por

posibles sospechas de backdoors, una mejora que se podría considerar en el futuro.

8. Conclusiones

En esta práctica hemos realizado el bastionado completo del servicio SSH en un servidor Ubuntu. Hemos implementado la autenticación mediante certificados digitales en clientes Windows y Linux. Aplicando las doce medidas de seguridad requeridas para el documento, analizando los logs con Inav y verificando las mejoras mediante lynis. Como valor añadido, hemos incorporado cinco medidas extra de fortificación alineadas con estándares internacionales.

Con este documento hemos demostrado que se ha obtenido un servidor significativamente más seguro que el de partida, con autenticación multifactor, protección contra fuerza bruta y una configuración criptográfica robusta. Esta práctica nos ha permitido comprender la importancia de un enfoque sistemático en la fortificación de sistemas frente a amenazas reales.

9. Webgrafía

Capítulo 2. Securización de los sistemas de administración remota de los contenidos de la UT6.

“Bash y SSH: establecer timeout por inactividad | rm-rf.es,” # rm-rf.es | Blog de un sysadmin Unix, GNU/Linux, Windows y lo que haga falta... Accessed: Feb. 25, 2026. [Online]. Available: <https://rm-rf.es/bash-y-ssh-establecer-timeout-por-inactividad/>

“4.2.3 Configuring SSH - server protocol 2.” Accessed: Feb. 25, 2026. [Online]. Available: https://www.tenable.com/audits/items/CIS_AIX_7.1_Benchmark_v1.1.0_Level_1.audit:eac74807ca1d10ef6fd48a00833fe0bf

“CIS Ubuntu Linux Benchmarks,” CIS. Accessed: Feb. 25, 2026. [Online]. Available: https://www.cisecurity.org/benchmark/ubuntu_linux

J. T. Force, “Security and Privacy Controls for Information Systems and Organizations,” National Institute of Standards and Technology, NIST Special

Publication (SP) 800-53 Rev. 5 (Withdrawn), Sep. 2020. Accessed: Feb. 25, 2026. [Online]. Available: <https://csrc.nist.gov/pubs/sp/800/53/r5/final>

“NIST Special Publication 800-63B.” Accessed: Feb. 25, 2026. [Online]. Available: <https://pages.nist.gov/sp800-63b.html>

“Home Page | CISA.” Accessed: Feb. 25, 2026. [Online]. Available: <https://www.cisa.gov/>

K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, “Technical Guide to Information Security Testing and Assessment,” National Institute of Standards and Technology, NIST Special Publication (SP) 800-115, Sep. 2008. doi: 10.6028/NIST.SP.800-115. Available: <https://csrc.nist.gov/pubs/sp/800/115/final>

“Network Device Hardening Standard | University of Missouri System.” Accessed: Feb. 25, 2026. [Online]. Available: <https://www.umsystem.edu/ums/is/infosec/network-device-hardening-standard>

J. Testa, *jtesta/ssh-audit*. (Feb. 25, 2026). Python. Accessed: Feb. 25, 2026. [Online]. Available: <https://github.com/jtesta/ssh-audit>

fail2ban/fail2ban. (Feb. 25, 2026). Python. Fail2Ban. Accessed: Feb. 25, 2026. [Online]. Available: <https://github.com/fail2ban/fail2ban>